

Narrativa Explicativa – Encuesta VAST Nacional

Porque las métricas sin relato son como logs sin SIEM: ruido con pretensiones de poesía.

1. Por qué esta encuesta

En los últimos años, la ciberseguridad ha dejado de ser una conversación exclusiva de técnicos para convertirse en un tema de consejo de administración y de titulares. La transposición de NIS2, la aplicación de DORA, la actualización del ENS y la creciente dependencia digital hacen que las decisiones sobre prevención, detección y respuesta ya no puedan tomarse a base de intuición y “corazonadas” bienintencionadas.

Esta encuesta nace para poner orden en ese debate: medir con cierto rigor el grado de madurez de las organizaciones españolas en modelado de amenazas y métricas de ciberseguridad. No para repartir medallas ni señalar con el dedo, sino para saber dónde estamos, qué nos falta y qué merece la pena impulsar.

2. Qué se entiende por enfoque “VAST”

VAST (Visual, Agile, Simple Threat) es una forma de recordar que el modelado de amenazas no tiene por qué ser un ejercicio esotérico reservado a gurús de pizarras llenas de flechas. La idea es:

- Visual: entender sistemas y procesos a través de diagramas claros, que puedan mirar desarrollo, operaciones y negocio sin perderse.
- Agile: integrar el análisis de amenazas en ciclos ágiles de desarrollo y despliegue, sin paralizar proyectos ni convertir la seguridad en el departamento del “no”.
- Simple: lo justo de sofisticación para ser útil y repetible, sin exigir doctorados en criptografía aplicada a cada sprint.

La encuesta no pretende verificar quién implementa el VAST más puro del planeta, sino quién ha conseguido llevar el espíritu de ese enfoque (visual, integrado, pragmático) al día a día de su gestión de ciber riesgos.

3. Qué mide la encuesta (más allá de los checklists)

La encuesta recorre desde la capa más política hasta la más operativa:

- Gobernanza y cumplimiento: quién manda aquí, qué marcos seguimos y si tenemos una estrategia algo más sólida que un PDF olvidado.
- Inventario y superficie de ataque: qué tenemos, dónde está y qué está expuesto (en serio, no solo lo que recordamos).
- Modelado de amenazas: si miramos nuestros sistemas desde los ojos de un adversario o seguimos confiando en que nadie se fijará en nosotros.
- Métricas y riesgo: qué medimos, cómo lo explicamos al negocio y si hablamos de euros o de adjetivos.
- Vulnerabilidades, terceros y cadena de suministro: porque hoy en día fallar por un proveedor despistado es casi un clásico literario.
- Respuesta, continuidad y resiliencia: qué hacemos cuando lo inevitable sucede y cuánto tardamos en dejar de improvisar.
- Talento y cultura: cuánta gente sabe de esto, cuánta quiere seguir sabiéndolo y cuánto porcentaje se nos va a la competencia.
- Visión de futuro: dónde pensamos invertir, si queda presupuesto y paciencia.

4. Para quién está pensada

La encuesta está dirigida a organizaciones que:

- Tienen un mínimo de responsabilidad sobre servicios esenciales, información sensible o procesos de alto impacto.
- Han pasado ya la fase de “esto de la ciberseguridad es cosa del informático” y la han convertido en un asunto de dirección.
- Entienden que admitir debilidades en una encuesta es menos doloroso que descubrirlas en portada de periódico.

No es un examen escolar. No hay aprobados y suspensos, solo grados de sinceridad y capacidad de mejora.

5. Cómo leer los resultados (sin autoengaños)

5.1. El Índice Global de Madurez (IGM)

El IGM es un intento de condensar en un número el estado de madurez de una organización. No es un oráculo ni una sentencia divina: es un indicador sintético que ayuda a comparar:

- Su organización consigo misma en el tiempo.
- Su organización con otras de su mismo sector y tamaño.
- El estado global de un sector frente a otros.

Un IGM bajo no significa “irresponsabilidad”, sino margen de mejora (y, probablemente, carencias de recursos o de foco estratégico). Un IGM alto no garantiza invulnerabilidad, pero sugiere que las batallas se están librando con algo más que buena voluntad.

5.2. Los bloques de madurez

La gracia está en mirar el detalle:

- Una organización puede estar fuerte en detección y respuesta, pero débil en modelado de amenazas (reacciona bien, pero anticipa poco).
- Otra puede tener un gobierno impecable en papel, pero métricas pobres y poco diálogo con negocio (mucho marco, poca práctica).
- Otra puede tener buen talento técnico pero nula capacidad de traducir sus hallazgos a impacto de negocio.

El objetivo no es “subir todas las barritas” a la vez, sino identificar qué bloques son cuellos de botella.

6. Sobre el ROI, la paciencia y los nervios

Hablar de ROI en ciberseguridad siempre genera esa mezcla de fascinación y sospecha. La encuesta y sus plantillas asociadas proponen una forma moderadamente razonable de estimar:

- Cuánto costarían incidentes sin ciertas medidas.
- Cuánto se ha reducido esa probabilidad o impacto gracias a las inversiones.
- Qué parte de esas inversiones se justifica (o no) a la luz de los datos.

No se trata de prometer que cada euro invertido se transformará en brillantes ahorros medibles, sino de evitar la situación en la que:

- Se invierte mucho sin ver mejoras claras.
- O se invierte poco y se espera un milagro permanente.

7. Qué hacer después de responder

Lo ideal sería:

1. Obtener su informe individual: ver el IGM, la posición relativa frente a organismos similares y las áreas de mejora.
2. Priorizar unas pocas acciones concretas: mejor tres prioridades ejecutables que un plan de 80 medidas que nadie financia.
3. Conectar la discusión con negocio: traducir “tenemos un THR bajo” a “la probabilidad de interrupción de este servicio crítico es inaceptable para nuestros objetivos”.
4. Repetir la encuesta cada cierto tiempo: la madurez no se mejora por inspiración, sino por iteración.

8. Epílogo (breve, lo prometo)

Si al terminar la encuesta siente que “lo estamos haciendo mejor de lo que pensaba”, enhorabuena: tiene razones para convencer a la organización de que siga por ahí.

Si siente que “estamos más verdes de lo que imaginaba”, enhorabuena también: ha ganado usted una claridad dolorosa pero útil. A partir de ahí, la conversación con la dirección puede girar de “no tenemos problemas” a “no queremos sorpresas”.

La ciberseguridad perfecta no existe; la transparencia honesta sobre dónde estamos, sí. Y es un punto de partida bastante decente.